

Electronic payment systems

P Putland, J Hill and D Tsapakidis

Trusted electronic payment systems are a key enabler for mass acceptance of electronic commerce over insecure networks such as the Internet. This paper classifies the currently available payment systems on the Internet, and looks at likely payment systems for the future. The need for micropayments is also discussed.

1. Introduction

The Internet has had a major influence on the way people access information, and many people are predicting it will have a similar influence on electronic commerce. Electronic commerce in its broadest sense is how telecommunications and computing technology are changing the way business is conducted, but the scope of this paper is restricted to how people will buy and pay for information, goods and services over the Internet. The past years have seen many businesses putting sites on-line, but most are there purely for an electronic presence, to market products or for customer support. Only a minority are actually carrying out electronic transactions in which the payment is initiated on-line, and if commerce is to flourish, then secure electronic payment systems, trusted by both merchants and users, are needed.

Electronic payment systems are not a new phenomenon. Consumers have become used to dealing with electronic systems when dealing with money, such as withdrawing physical cash via an automated teller machine (ATM), or paying for groceries using a credit or debit card at an electronic point of sale terminal in a supermarket. These transactions are initiated from a secure terminal and carried over secure networks. The Internet has the potential to extend the reach of electronic payment into a new mass market, where the users can be making purchases over an insecure network from a range of terminals, and where traditional forms of payment (notes and coins, credit/debit cards and signatures) are replaced by their electronic equivalents (electronic cash, certificates and digital signatures).

Internet users are a very diverse population. Diverse in terms of location and culture as well as in terms of their reasons for using the Internet. Just as in the physical world, there is scope for a wide range of different sorts of financial

transaction, from small payments for goods and services, or gifts to friends, through to large transactions between businesses. Depending on its application, there are a number of requirements that an electronic payment system may need to satisfy, including:

- confidentiality — any data transferred must not be accessible to eavesdroppers,
- authentication — communicating parties must be certain of each other's identity,
- integrity — communicating parties must be certain that data has not been tampered with,
- non-repudiation — it must be possible to prove a transaction has taken place at a certain time,
- trust — users must trust any systems they use,
- anonymity — the real identity of certain communicating parties are not revealed,
- untraceability — who spent what and where is not revealed.

The range of payment systems proposed and in use have different approaches to addressing these problems. Some provide all features, while others only have a few of them.

1.1 Transaction profiles

It is useful to consider different transaction profiles and the impact on security requirements. In all cases, there is a payer and a payee. The vast majority of transactions conducted on the Internet today are consumer transactions, in which the payee is a merchant selling goods or services. In most cases, the payer and payee will view each other as

adversaries with very little reason to trust one another. Authentication and non-repudiation are important security requirements. Often there will be a unequal balance of resources in a consumer transaction, with the payee being more powerful than the payer. A number of payment systems recognise this fact, for example by giving anonymity to the payer while identifying the payee.

Interbusiness transactions are not yet common on the Internet, but there is increasing interest in using the Internet as a private network which could well carry such transactions, and there are predictions that by the year 2000, the majority of electronic commerce transactions will be business-to-business [1]. Interbusiness transactions could be much larger than typical consumer ones, so integrity becomes very important. Confidentiality will also be very important, but there will be less need for anonymity and untraceability in these transactions. A third class are interpersonal transactions. These are transactions where neither payer nor payee are particularly powerful.

1.2 Types of transaction system

There are basically three different types of transaction system — card, cheque and cash systems. Cards and cheques are indirect payment mechanisms. Indirect payments are useful when payer and payee do not trust one another. Settlement is made through a mutually trusted third party (the bank). Cash is a direct mechanism in which the payer credits the payee without the aid of a third party.

Card transactions

The main feature of a card transaction is that it is processed on the existing credit card clearing infrastructure used by retailers and mail order companies. In a card transaction system, the payer is issued with a card by an issuing bank. The card allows them to make purchases at merchants who accept that particular card. The merchant has an agreement with an acquiring bank, who processes card transactions on the merchant's behalf.

To make a card transaction, the merchant submits a payment instruction to the acquiring bank. This instruction encodes the card number, together with the transaction amount, merchant identification and (optionally) the customer's signature. The merchant may also obtain authorisation for the transaction to verify that the card has not been revoked. The payment instruction is then passed from acquirer to issuer when the transaction is processed. If the payment is authorised by the issuer, then settlement follows. The customer's account with the issuer is debited and the merchant's account with the acquirer credited.

Cards are the preferred instrument for consumer commerce. The transactions are regulated by consumer credit legislation. As a result, they offer the customer a good

level of protection from unscrupulous merchants. This is especially relevant to 'cardholder not present' (CNP) transactions for which there is no customer signature on the payment instruction. CNP transactions include mail, telephone orders and, currently, all transactions initiated on the Internet. In the UK, trade practices mean that merchants assume complete liability for a CNP transaction, which basically means that the customer can dispute any transaction made (legitimately or otherwise). The CNP regulations may appear unduly harsh to merchants, but the ability to make CNP transactions has, to some extent, jump-started Internet commerce by providing a way of making payments without the need to develop any Internet specific mechanisms.

Cheque transactions

Cheque transactions are similar to card transactions in that they are settled indirectly through a third party. The main difference is that cheques are cleared on presentation, rather than at regular intervals. Also, cheque transactions may be processed entirely on the Internet since they do not rely on any legacy systems. A final difference is that unlike card transactions, cheque transactions are not explicitly regulated.

A cheque is a signed instruction to the payer's bank to credit the account of the payee. There are a number of different models for cheque transactions [2, 3], but the main feature is the use of a signature and a serial number which allows the payer's bank to verify that the cheque is valid and that it has not previously been spent.

Cash transactions

The final type of transaction system is cash. Cash transfers value directly between payer and payee. There is no third party involved in the transaction, which raises questions about how to prevent users copying and double spending cash. The only way to prevent this is through the use of a tamper proof device (i.e. a smart card) to store the value. This means that a cash system requires a substantial amount of infrastructure, in terms of cards and card readers.

2. Current transaction systems

The major systems in current use on the Internet are all card or cheque systems. There are no cash systems in common use, although the concept has been demonstrated.

2.1 Card payment systems

Credit cards currently dominate transactions on the Internet, and as a payment mechanism have several advantages:

- in order to accept a card, a merchant must have a banking relationship with a card acquirer, providing the customer assurance of the basic integrity of the merchant,
- should someone make fraudulent use of the card, the consumer has the protection of the law in some countries (such as the US and UK) for purchases they have not authorised,
- credit cards may offer insurance on the goods purchased,
- some credit cards are global in nature (i.e. some brands are accepted world-wide), and allow purchases to be made in the local currency of the merchant, while being settled in the consumer's domestic currency.

There are also several disadvantages for credit card transactions:

- the high transaction fees paid by merchants in some countries as they are 'card holder not present' transactions,
- the requirement of a relationship with a credit card acquirer is a barrier to some merchants,
- the perceived security risk of passing credit card numbers over the Internet.

The need for a relationship with an acquirer means that this payment mechanism is not suitable for individuals wanting to sell items over the Internet. The cost per transaction also makes it unsuitable for low value items, unless some form of aggregation is used.

Simple card payments

The simplest form of card payment over the Internet is where a customer provides the number to the merchant, who then requests an authorisation from their card acquirer prior to delivering the goods. This is very similar to a telephone-based transaction, and all that has occurred is the transmission of a card number. The confidentiality of the card number is provided by using secure socket layer (SSL) encryption at the network level between the client and the merchant's server. The merchant has to trust the customer, as they have no way of identifying the customer, as the only information available is a credit card number. The customer has a limited amount of trust in the merchant, in that to provide the SSL connection the merchant must have a certificate installed on their server that has been signed by a certificate authority [4]. As the transaction only involved passing the card number, there are no audit trails (covering issues such as the item ordered, price and time of order) surrounding the purchase. The main use of this type of payment at present is by merchants selling hard goods, where the authorisation of the card number can be carried

out off-line using the same systems as for telephone orders, and the merchant also has a delivery address to help identify customers. The lack of on-line authorisation also keeps the cost of the service down, as an on-line authorisation link, and associated secure infrastructure, is expensive and a barrier to small merchants. The need for a low-cost solution for merchants who need on-line authorisation (typically those selling soft goods for immediate fulfilment) has led to the growing use of transaction switches.

Payment switches

Payment switches are secure servers that provide centralised functionality and support for merchants wishing to sell over the Internet. The payment switch has on-line links into the financial institutions, and the merchants simply direct payment instructions through the switch for validation, authentication and authorisation. Any merchant who wishes to use the service has to register with the switch, and part of the registration involves an exchange of public keys [4]. The merchant then creates their web site of items to sell, and each item for sale has an offer (associated with a 'buy' button) which is a URL pointing to the transaction switch. The offer is protected by a hash value [5], which can only be computed by the merchant or switch as only they have knowledge of the key used to produce the hash value (the keys used to create the hash values are initially sent during registration and encrypted using public-key cryptography). This hash value prevents users from altering details of the offer (such as price) and gives integrity to the system. When a user wants to purchase an item, they click on the appropriate offer, and are directed to the payment switch which is responsible for checking the integrity of the offer by calculating and comparing hash values, authenticating the user, authorising the payment, and informing the merchant that the goods should be delivered. The payment switch maintains a log of all transactions, which can be used in case of any later disputes. Other advantages of payment switches are that as only the switch has knowledge of the card details, the user only has to trust the switch operator, and not every merchant which they buy from, and allowing users to register their card number with the switch means that the number is only sent over the network once.

Both of the above methods rely on network level SSL encryption to encrypt credit card details that are passing over the Internet, a process that is invisible to the client and server applications. An alternative approach is to use a cryptographic protocol at the application level, rather than relying on the network to provide a secure channel. This is the basis for so-called 'crypto-card protocols'.

Crypto-card protocols

A far more advanced technique is to use an application-level cryptographic protocol to protect information as it is

sent over the Internet. This is a technique first described by IBM in their iKP protocol suite [6] and deployed since in similar ways in the CyberCash and SET protocols.

The main feature of these systems is their use of public key cryptography to protect the payment instruction and (optionally) provide strong proof that the customer authorised the transaction. In their simplest form, only the acquiring bank has a public/private-key pair. When the user wishes to make a payment, they encrypt the payment instruction using the public key of the acquirer. In this way, the merchant has no access to the payment information. The acquirer decrypts the payment instruction and returns a success or failure message to the merchant.

It is possible to extend this protocol by issuing key pairs to the merchant. The merchant can then authenticate himself strongly to the customer and to his acquiring bank; this is how the current SET trials operate. Similarly, if the customer is also issued with a key pair, they can sign the payment instruction to provide strong authorisation for the transaction; this is how the CyberCash protocol works.

2.2 Electronic cheques

The other current form of payment on the Internet is electronic cheques, although some people also refer to these technologies as electronic cash. The distinction being made here is that electronic cheques involve three parties to carry out a transaction (bank, purchaser, and the merchant), whereas a true electronic cash transaction is a two party protocol involving only the purchaser and seller.

In an electronic cheque model, the bank's role is to create the cheques, exchange the electronic cheques for real money, and to validate any cheques used in a transaction. The cheques are signed by the issuing bank to prevent users trying to generate cheques themselves, and different signature keys can be used to provide different values for each denomination. The customer buys cheques from an issuing bank and stores them locally on their client. The cheques can then be used at any merchant accepting this brand of cheques, and the customer does not need to open an account with each merchant. On receipt of a cheque, or cheques, the merchant forwards them to the issuing bank, which confirms that they have not previously been spent, and credits the merchant's account. Notification is sent back to the merchant that the goods can be delivered. The involvement of the bank in any transaction is crucial to the use of the system, and the bank is acting as a trusted third party.

For payer anonymity, a blind signature technique can be used, as in the Digicash e-cash system. For blind signature

cheques, the customer generates the cheque, rather than the bank, adds a 'blinding' factor and sends it to the bank for signing. The bank does not know the blinding factor, so cannot identify the cheques, but can sign the cheques with the appropriate key for the denomination required. The bank returns the cheques to the user, where the blinding factor is divided out to leave the valid signed cheques. The bank can still verify that the cheque is valid as verification involves checking their digital signature generated from the cheque. The bank has no record of who created what cheques, providing the required anonymity for the customer, although the merchant is still known by the bank for each transaction.

3. Future payment systems

3.1 Card based

The secure electronic transaction (SET) protocol [7] is a joint development by several leading companies in the payments industry to standardise card payments over the Internet. The SET protocol is a crypto-card protocol, in that it relies on application-level cryptography to overcome the problems of confidentiality and integrity, and introduces the concept of a dual signature. As the SET protocol ensures that any information should only be accessible to the parties who need to know that information, the order information is only known to the customer and merchant, while the payment details are only known to the customer and financial acquirer, dual signatures being used to provide the integrity of the whole process.

In the fully implemented protocol, all parties (purchaser, merchant and acquirer gateway) have two specific SET certificates, one for signing and one for encryption. For efficiency, many of the message encryptions are actually carried out using symmetric keys generated per transaction, where the symmetric keys are encrypted using the message recipient's public key and sent with the encrypted message. The SET specifications state that the use of a cardholder certificate is optional, and in initial trials it is likely that the purchaser will not have a certificate, which means that they will not be able to produce a digital signature, so any orders will not be authenticated. In place of a digital signature, the customer can simply generate the hash of the payment instruction and encrypt this with the payment gateway's public key. An overview of a purchase using the full three-key pair SET protocol is given below.

- The purchaser has completed an order form, either generated locally on the client or from the merchant's server, and their client requests the merchant's public key, and that of the merchant's payment gateway for the card used by the purchaser. The merchant allocates a unique reference to the transaction and returns the public keys.

- The customer's software creates two separate messages — the order information and payment instructions — with the unique reference in both messages to provide the link between the order and payment. The user generates a dual signature, which is obtained by calculating hash values of both messages, concatenating them together, calculating the hash of this and signing it with their private key. The user also encrypts the payment instructions using the payment gateway's public key, and sends the order information, encrypted payment information, dual signature, and hash value of the payment message to the merchant.
- On receipt of the order, the merchant needs to check the integrity and authenticity of the messages. Firstly, the merchant checks the order information and produces a hash value of the message. This is concatenated with the hash value of the payment instruction and a final hash produced. The dual signature sent by the customer is decrypted using the customer's public key, and checked with the final hash value produced by the merchant. This checks that the order was signed using the customer's private key, authenticating the customer, and also has ensured the message integrity as any tampering would change the hash values produced. Thus, although not able to read the payment instructions, the merchant can check the overall integrity of the message, and authenticate the user, by checking the dual signature.
- The merchant then requests authorisation, by signing an authorisation request and encrypting using the payment gateway's public key. The request, along with the customer's payment instructions and a hash of the order information, is sent to the payment gateway.
- The payment gateway decrypts the authorisation request and the customer's payment instructions, and checks the dual signature using the hash of the ordering information and computing the hash of the payment instruction. This ensures the integrity of the message, as any tampering of the payment instruction would be detected at this stage. The payment gateway can then authorise the payment if appropriate and send a response to the merchant.

3.2 *Electronic cash*

The risks of fraud due to copied cheques or double spending are too high for software only implementations, and true electronic cash (a peer-to-peer anonymous transaction involving two parties only) is reliant on some form of trusted device. The obvious candidates at present for these devices are stored-value smart cards. This means that true electronic cash transactions will not occur until smart cards and readers are commonplace. The security features and transaction protocols of these cards take on the role of authenticating the payments, which was carried out

by on-line banks in software implementations of electronic cheques. It is likely that the advent of smart cards, such as Mondex, will play a leading role in the realm of digital cash. The lack of a third party involved in the transaction reduces the cost per transaction, giving true electronic cash an advantage for low-value payments, where anonymity and lack of audit trails are acceptable.

3.3 *Micropayments*

All of the payment systems considered thus far are designed for making arbitrarily large payments. They are quite capable of handling individual payments with values of thousands of pounds or more. At the other end of the spectrum are a whole range of pay-as-you-go applications where the cost of the items being purchased are pennies per page or less. Conventional payment systems do not handle small payments such as these efficiently because their per-transaction costs are prohibitively large. This is the realm of so-called micropayments, which are essentially transactions where the per-transaction overheads are reduced to a level that makes small-value payments economic.

The most expensive part of any transaction is the settlement phase, where the actual value is transferred from buyer to seller. Micropayment systems work by divorcing the settlement phase from the payment so that a single settlement can be made for a number of micropayments. The overheads are further reduced by relaxing the security, messaging and auditing requirements, for example, by using techniques such as hash functions rather than digital signatures as hash functions are computationally cheaper. Settlement can be done either before (pre-payment) or after (post-payment) any micropayments are made. Any conventional payment instrument can be used for this (i.e. credit card). Pre-paid schemes have the advantage of reduced fraud risk, which may make them cheaper to operate than post-paid systems.

Several different micropayment schemes have been proposed and they can be categorised in many ways. They generally follow similar protocols but differ in characteristics such as coin issue, spending method, theft prevention and coin denomination. The most important cost factor is coin representation (the way a coin is encoded) and this is the characteristic considered here. The main methods of coin representation are as chains of hash values, or as random tokens.

Hash value chain

Hash chains are a particularly efficient coin representation for post-paid micropayments. A hash function is a one-way transformation which maps an arbitrarily large message to a fixed-length digest. Hash functions are very quick to compute in the forward direction, but it should be impossible to work backwards

from the digest to the original message. A hash chain is constructed by repeatedly hashing a randomly chosen seed and can be used to relate a whole series of transactions to a single payment instruction.

The customer starts by deciding how many transactions they are likely to make with a particular merchant. This does not have to be an accurate guess, though it is better to guess too high than too low. Call this number n . The customer then chooses a random seed for the hash chain (call this ∂_n) and hashes it n times to form the chain:

$$\begin{aligned}\partial_{n-1} &= H(\partial_n) \\ \partial_{n-2} &= H(\partial_{n-1}) \\ \partial_{n-3} &= H(\partial_{n-2}) \\ \partial_{n-4} &= H(\partial_{n-3}) \\ &\dots \\ \partial_0 &= H(\partial_1)\end{aligned}$$

The value ∂_0 is the root of the chain. Knowledge of ∂_0 tells you nothing about the next value ∂_1 because $H()$ is a one-way function. However, when ∂_1 is revealed, it is a simple matter to verify that $\partial_0 = H(\partial_1)$. By signing the root value using a public-key algorithm, the customer can commit to an entire series of payments without knowing exactly how many will be made. This technique is used in PayWord, Netcard and others.

Random token

While the hash chain representation is very efficient for post-paid micropayments, it is not easily applied to the pre-payment case. The principle problems are wastage and lack of control over double spending. In fact, double spending is the single biggest threat to pre-paid schemes. The solutions to this problem are either through the use of tamper resistant devices (i.e. smart cards), or by performing on-line verification of each transaction. In a software pre-payment scheme, on-line verification is essential, and therefore the goal is to make all the messaging and computations as lightweight as possible. The random token representation is good in these areas.

In the random token representation the coins are a list of unrelated random numbers. To make a payment, the customer simply reveals the next value in the series to the merchant. The merchant performs an on-line check with the bank to verify that this value is correct. No computation is performed by either customer or merchant and the messages they send are very short. The random token representation requires that the bank store a copy of all the tokens issued to customers and this could mean that the bank's requirement for storage is huge. To make this system scale, the bank diversifies every set of coins from the same set of random

numbers. A different key is used to encrypt the coins for each user, so the per user storage requirements are minimised. However, this does mean that the bank must perform an encryption in order to verify each coin. This technique is employed in BT's QuickPay system.

4. Conclusions

The wide acceptance of Internet payment systems are key to their use. The advances in technology, and the backing of key industry brand names like VISA and Mastercard, mean that public perception of making payments over the Internet should change in the near future. The range of payment systems fully supported and used is likely to decrease from those currently being proposed or prototyped, with the SET protocol becoming dominant in the near term for card payments, and stored-value smart cards rising in importance as the infrastructure to support them (particularly card readers) becomes more widely available. The advent of micropayment technologies will enable many pay-as-you-go applications and new business opportunities for providers of information or pieces of code that only cost a few pence or even fractions of a penny.

References

- 1 'The global market forecast for internet commerce', Internet Commerce Report, IDC Number: W12339 (November 1996).
- 2 <http://www.cwi.nl/~brands/cash.html>
- 3 <http://www.digicash.com>
- 4 Skevington P J and Hart T J: 'Trusted third parties in electronic commerce', BT Technol J, 15, No 2, pp 39—44 (January 1997).
- 5 Phoenix S J D: 'Cryptography, trusted third parties and escrow', BT Technol J, 15, No 2, pp 45—62 (January 1997).
- 6 Bellare M et al: 'iKP — a family of secure electronic payment protocols', First USENIX Workshop on Electronic Commerce (<http://www.zurich.ibm.com/Technology/Security/publications/1995/ikp.ps.gz>) (1995).
- 7 <http://www.mastercard.com/set/>



Paul Putland joined BT Laboratories in 1985 after graduating in Physics from the University of Exeter. He initially worked on the reliability and analysis of semiconductor devices for optical transmission systems, and gained an MSc in the Physics of Laser Communications from Essex University in 1992. In 1992 he joined the applications unit within Advanced Applications and Technologies to work on a business re-engineering project. Since 1995, he has been working in the area of electronic commerce and the Internet.



Jake Hill joined BT in 1993 after gaining an MEng in Electronic Systems Engineering at Aston University, Birmingham. He has worked in the fields of computer security and cryptographic protocol design.

Since 1995 he has been involved in a number of Internet commerce programs and is currently working on micropayment systems.



Dimitrios Tsapakidis obtained a BSc in Mathematics and Computer Science from Imperial College in 1995, with a thesis on implementing a generic parallel genetic algorithm. He obtained an MSc in Information Security from Royal Holloway, University of London in 1996, with a thesis on designing cryptographic matchmaking protocols.

He joined the BT Laboratories Security Research group in 1996 and has since been working on micropayments.